মানুষকে হ্যাক করার সম্পূর্ণ গাইড — Attack ও Defense

Technology নয়, মানুষের মনস্তত্ত্বই সবচেয়ে বড় vulnerability। Phishing থেকে Vishing, Pretexting থেকে Physical Intrusion — সব কিছু বুঝো এবং নিজেকে ও প্রতিষ্ঠানকে রক্ষা করো।

📋 সূচিপত্র

01. Social Engineering কী এবং কেন কাজ করে

মনস্তত্ত্ব, Influence Principles, Attack Lifecycle

02. Phishing — সবচেয়ে বেশি ব্যবহৃত Attack

Spear Phishing, Whaling, Clone Phishing, চেনার উপায়

03. Vishing ও Smishing

Phone Scams, SMS Attacks, Caller ID Spoofing

04. Pretexting ও Impersonation

Fake Identities, Authority Abuse, IT Support Scam

05. Physical Social Engineering

Tailgating, Shoulder Surfing, Dumpster Diving, Baiting

06. OSINT — Target Research

LinkedIn, Facebook, Google Dorking, theHarvester

07. SET Toolkit — Pentest Framework

Credential Harvester, Phishing Simulation, Payload Delivery

08. Real-World Attack Cases

Bangladesh Bank Heist, Twitter Hack, COVID Scams

09. Defense ও Awareness Training

User Training, Policy, Technical Controls, Incident Response

10. Phishing Simulation Program

GoPhish, Campaign Planning, Metrics, Reporting

CHAPTER 01

🧠 Social Engineering কী এবং কেন কাজ করে

মানুষের মনস্তত্ত্বই সবচেয়ে বড় security vulnerability

🎭 Social Engineering সংজ্ঞা

Social Engineering হলো মানুষকে মনস্তাত্ত্বিকভাবে manipulate করে তাদের কাছ থেকে গোপন তথ্য বা access পাওয়ার পদ্ধতি। Kevin Mitnick — বিশ্বের সবচেয়ে বিখ্যাত hacker — বলেছিলেন: "The human factor is truly security's weakest link." প্রযুক্তি যতই শক্তিশালী হোক, মানুষের ভুল করার প্রবণতা থাকবেই।

> 💡 **মূল কথা:** ৯৫% সাইবার attack-এ human error কোনো না কোনোভাবে জড়িত। Firewall বা Antivirus কোনো software-ই এটা আটকাতে পারে না।

🧬 কেন কাজ করে — ৬টি মনস্তাত্ত্বিক Principle

Robert Cialdini-র "Influence" বই অনুযায়ী, মানুষ ৬টি মূল principle-এ সহজে প্রভাবিত হয়। Attacker-রা এগুলো exploit করে।

Principle	মানে	Attack Example	Defense
🏛 **Authority**	কর্তৃপক্ষকে মানি	"আমি CEO বলছি, এখনই পাঠাও"	Phone করে verify করো
⏰ **Urgency**	সময়ের চাপ	"আজকেই না করলে account বন্ধ"	থামো, ভাবো, verify করো
😨 **Fear**	ভয় দেখানো	"আপনার computer-এ virus!"	Cold call-এ কখনো action নাও না
🤝 **Reciprocity**	উপকার করলে ফেরত দেই	USB gift দিয়ে malware ছড়ানো	অপরিচিতের gift নাও না

Principle	মানে	Attack Example	Defense
👥 Social Proof	সবাই করছে তাই আমিও	"আপনার সব colleague-রা sign করেছে"	নিজে independently verify করো
🤗 Liking	পছন্দের মানুষকে বিশ্বাস করি	Rapport build করে info চাওয়া	পরিচিতি ≠ trustworthy

🔄 Social Engineering Attack Lifecycle

1	🔍 Research	Target সম্পর্কে তথ্য সংগ্রহ — LinkedIn, Facebook, company website, OSINT
2	🎯 Target Selection	কে সবচেয়ে সহজ শিকার? New employee, receptionist, IT helpdesk
3	🎭 Pretext Building	বিশ্বাসযোগ্য story তৈরি করো — "আমি IT dept থেকে"
4	⚡ Attack Execution	Phishing email / phone call / physical visit — action নাও
5	📦 Exploitation	পাওয়া credentials/access দিয়ে system এ ঢোকো
6	🧹 Cover Tracks	প্রমাণ মুছে ফেলো, victim জানতেই পারে না

📊 Attack Statistics

95%

সাইবার breach-এ human error জড়িত

3.4B

Phishing email প্রতিদিন পাঠানো হয়

$4.91M

Social engineering breach-এর গড় খরচ

✅ Chapter 1 Summary

✓ Social Engineering = technology নয়, মানুষকে manipulate করা

✓ Authority, Urgency, Fear — এই ৩টি সবচেয়ে বেশি ব্যবহৃত

✓ Attack lifecycle জানলে defense করা সহজ হয়

✓ ৯৫% breach-এ মানুষের ভুলই দায়ী

CHAPTER 02

🎣 Phishing — সবচেয়ে বেশি ব্যবহৃত Attack

Email-based deception — সব ধরন, চেনার উপায় ও defense

🎣 Phishing-এর প্রকারভেদ

🎣 Regular Phishing

Mass email — লক্ষ লক্ষ মানুষকে একই email পাঠানো। "আপনার bank account বন্ধ হচ্ছে"

Mass Target

🎯 Spear Phishing

Specific ব্যক্তিকে target করে। তার নাম, position, colleague-র নাম ব্যবহার করে personalized email।

High Success Rate

🐳 Whaling

CEO, CFO, CISO — Senior executive-দের target করে। বড় financial বা data theft-এর জন্য।

High Value Target

📋 Clone Phishing

Legitimate email-এর হুবহু copy তৈরি করে malicious link যোগ করা। "Resending your invoice"

Hard to Detect

👔 BEC (Business Email Compromise)

CEO বা trusted partner-এর email impersonate করে wire transfer বা data request।

$26B+ Global Losses

🈂️ Pharming

DNS poisoning দিয়ে legitimate website-এ গেলে fake site-এ redirect করা।

No Link to Click

🔍 একটা Real Phishing Email বিশ্লেষণ

```
── PHISHING EMAIL ANATOMY ──

From: security-alert@paypa1.com        ← ⚠️ paypal নয়, paypa1 (l→1 swap)
To: victim@company.com
Subject: 🚨 Urgent: Your Account Will Be Suspended!   ← ⚠️ Urgency + Fea
Date: Mon, 15 Jan 2024 03:42:11 +0000  ← ⚠️ রাত ৩টায় পাঠানো

Dear Valued Customer,                  ← ⚠️ নাম নেই = mass phishing

We have detected SUSPICIOUS ACTIVITY on your PayPal account.
Your account will be PERMANENTLY SUSPENDED within 24 hours
unless you verify your information IMMEDIATELY.        ← ⚠️ Urgency + F

Click here to verify: http://paypal-secure-verify.xyz/login  ← ⚠️ Fake d

Best regards,
PayPal Security Team                   ← ⚠️ Fake signature

── RED FLAGS চেকলিস্ট ──
❌ Sender domain: paypa1.com (typosquat)
❌ Generic greeting ("Dear Customer")
❌ Urgency language ("24 hours", "IMMEDIATELY")
❌ Fear tactics ("PERMANENTLY SUSPENDED")
❌ Suspicious link domain (.xyz)
```

❌ রাত ৩টায় পাঠানো
❌ Excessive capitalization

🔗 Malicious URL চেনার উপায়

```
── LEGITIMATE vs MALICIOUS URL ──

✅ Legitimate:
https://www.paypal.com/signin
https://online.bankofamerica.com/login
https://accounts.google.com/

⚠️ Typosquatting (অক্ষর পরিবর্তন):
http://paypa1.com          ← l → 1
http://paypai.com          ← l → i
http://paypaI.com          ← l → I (capital)
http://pay-pal.com         ← hyphen যোগ
http://paypal.com.login.xyz ← subdomain trick

⚠️ Subdomain Trick:
http://paypal.com.malicious.xyz/login
   ↑ এটা paypal.com নয়! Domain = malicious.xyz

⚠️ URL Shortener (real URL লুকানো):
http://bit.ly/3xY9kLm   ← কোথায় নিয়ে যাবে জানো না

⚠️ HTTP (no S):
http://yourbank.com/login  ← SSL নেই = unsafe

── URL CHECK TOOLS ──
https://virustotal.com       ← URL scan করো
https://urlscan.io           ← Detailed analysis
https://phishtank.org        ← Known phishing DB
https://safebrowsing.google.com/safebrowsing/report_phish/
```

📧 Email Header Analysis

```
# Email header দেখো (Gmail: More → Show Original)
# আসল sender বের করো

── IMPORTANT HEADER FIELDS ──

From: display name <real@sender.com>
  └─ Display name ≠ Real email address!
  └─ "PayPal Support" <hacker@evil.com> — fake!

Return-Path: bounced@different-domain.com
  └─ From ≠ Return-Path → suspicious!

Received: from mail.sender.com (IP: 1.2.3.4)
  └─ আসল sending server

SPF: FAIL / SOFTFAIL
  └─ Sender authorized নয় → phishing!

DKIM: FAIL
  └─ Email tampered হয়েছে → phishing!

DMARC: FAIL
  └─ Domain policy violation → phishing!

── Python দিয়ে header parse করো ──
import email
from email import policy

with open("email.eml", "rb") as f:
    msg = email.message_from_binary_file(f, policy=policy.default)

print(f"From:        {msg['From']}")
print(f"Return-Path: {msg['Return-Path']}")
print(f"Reply-To:    {msg['Reply-To']}")
print(f"Subject:     {msg['Subject']}")
print(f"Date:        {msg['Date']}")

# All Received headers (email path)
for received in msg.get_all('Received', []):
    print(f"Received: {received[:100]}")
```

📊 Email Authentication — SPF, DKIM, DMARC

Protocol	কী করে	কীভাবে কাজ করে	DNS Record
SPF	Authorized sender server চেক করে	DNS-এ কোন IP থেকে email আসতে পারে তা define করা	TXT v=spf1 ip4:...
DKIM	Email tamper হয়েছে কিনা চেক করে	Private key দিয়ে sign, public key দিয়ে verify	TXT selector._domainkey
DMARC	SPF/DKIM fail হলে কী করবে	Policy: none / quarantine / reject	TXT _dmarc.domain.com

```
# DNS-এ SPF record চেক করো
$ dig TXT domain.com | grep spf
v=spf1 include:_spf.google.com ~all

# DMARC record চেক করো
$ dig TXT _dmarc.domain.com
v=DMARC1; p=reject; rua=mailto:dmarc@domain.com
# p=none (just monitor), p=quarantine (spam), p=reject (block)

# DKIM check
$ dig TXT selector1._domainkey.domain.com
```

✅ Chapter 2 Summary

✓ Spear Phishing = personalized = সবচেয়ে বিপজ্জনক

✓ URL-এ typosquat, subdomain trick, HTTP চেক করো

✓ Email header-এ SPF/DKIM/DMARC FAIL মানে phishing সম্ভাবনা

✓ Generic greeting + urgency + fear = phishing সংকেত

CHAPTER 03

📞 Vishing ও Smishing

Phone ও SMS-based attacks — কীভাবে চিনবো ও রক্ষা পাবো

📞 Vishing — Voice Phishing

Vishing মানে phone call-এর মাধ্যমে প্রতারণা। Attacker নিজেকে bank, telecom, government বা IT support হিসেবে পরিচয় দেয়। Voice-এ বিশ্বাসযোগ্যতা তৈরি করা সহজ।

সবচেয়ে সাধারণ Vishing Scenarios

🏦 **Bank Scam**

"আমি Dutch-Bangla Bank থেকে বলছি। আপনার account সন্দেহজনক transaction হচ্ছে। Verify করতে OTP বলুন।"

⛔ কোনো bank কখনো OTP চায় না

💻 **IT Support Scam**

"আমি Microsoft থেকে বলছি। আপনার PC-তে virus আছে। TeamViewer install করুন।"

⛔ Microsoft কখনো unsolicited call করে না

🏛 **Government Scam**

"আমি NBR থেকে বলছি। আপনার tax pending আছে। এখনই payment না করলে arrest হবে।"

> ⛔ Government phone-এ payment নেয় না

🎁 **Prize Scam**

"আপনি lottery জিতেছেন! পুরস্কার পেতে processing fee পাঠান।"

> ⛔ কেউ lottery জেতায় না

📲 Caller ID Spoofing

Caller ID Spoofing মানে fake phone number দেখানো। Attacker আপনার bank-এর নম্বর থেকে call করছে বলে মনে করিয়ে দিতে পারে — কিন্তু সেটা নকল।

```
Caller ID Spoofing Tools (pentest/awareness):
- SpoofCard (commercial service)
- Twilio API (programmable voice)
- Asterisk VoIP PBX

Defense:
→ Caller ID দেখে বিশ্বাস করো না
→ Call শেষ করে নিজে official number-এ call করো
→ Truecaller ব্যবহার করো (spam detection)
→ Bank-এর official app-এ check করো
```

📱 Smishing — SMS Phishing

Smishing = SMS + Phishing। SMS-এ malicious link পাঠানো। মানুষ phone-এ URL ভালো দেখতে পায় না, তাই click করে ফেলে।

```
── REAL SMISHING EXAMPLES ──

Example 1: Delivery Scam
"[bKash]: আপনার delivery hold আছে।
Confirm করুন: http://bkash-track.xyz/verify"
```

```
→ bkash.com নয়! bkash-track.xyz = fake

Example 2: Bank Alert
"DBBL: Suspicious login detected!
Secure your account: http://bit.ly/3xkLm9p"
→ URL shortener দিয়ে real URL লুকানো

Example 3: Prize Notification
"Congratulations! You won BDT 50,000.
Claim: http://grameenphone-prize.com"
→ GP-র official domain এটা নয়

── SMISHING RED FLAGS ──
❌ Unexpected message from unknown number
❌ URL shortener (bit.ly, tinyurl)
❌ Urgency ("আজকেই claim করুন")
❌ Personal information চাওয়া
❌ Official domain নয় (typosquat)
❌ অনুরোধ না করেও OTP আসা
```

🛡️ Vishing/Smishing Defense

🛡️ যা করবে

- ✅ Call শেষ করে official number-এ callback করো
- ✅ Bank-এর app থেকে নিজে চেক করো
- ✅ Truecaller/spam filter ব্যবহার করো
- ✅ SMS link কখনো directly click করো না
- ✅ Trusted person-এর সাথে confirm করো

⛔ যা করবে না

- ❌ Phone-এ OTP, PIN বা password বলবে না
- ❌ Remote access software install করবে না
- ❌ Urgent payment করবে না
- ❌ Gift card দিয়ে payment করবে না
- ❌ Personal info confirm করবে না

✅ Chapter 3 Summary

✓ Vishing = phone call scam — bank/government/IT support impersonation

✓ Caller ID সহজেই spoof করা যায় — দেখে বিশ্বাস করো না

✓ Smishing = SMS-এ malicious link — phone-এ URL ভালো দেখা যায় না

✓ OTP কখনো phone-এ বলো না — কোনো bank চায় না

CHAPTER 04

🎭 Pretexting ও Impersonation

Fake identity তৈরি করে target-কে বিশ্বাস করানো

🎭 Pretexting কী?

Pretexting মানে একটা বিশ্বাসযোগ্য scenario বা backstory তৈরি করা যাতে victim নিজেই তথ্য দিয়ে দেয়। এটা সব Social Engineering attack-এর core।

👔 Common Pretext Scenarios

Pretext	Scenario	কী চাওয়া হয়	Protection
💻 IT Support	"আমি helpdesk থেকে, আপনার password reset করতে হবে"	Password, remote access	Ticket number চাও, callback verify
👤 New Employee	"আমি নতুন join করেছি, আমাকে কি access দেবেন?"	Badge, login, building access	HR-এর সাথে confirm করো
🔍 Auditor	"আমি external auditor, document দরকার"	Financial/sensitive data	Management-এর approval নাও
🏢 Vendor	"আমি software vendor, maintenance করতে এসেছি"	Physical/system access	Pre-scheduled না হলে deny
📰 Journalist	"আমি সাংবাদিক, company সম্পর্কে জানতে চাই"	Internal processes, staff info	PR/legal-এ refer করো
😰 Distressed Person	"আমার মেয়ে accident-এ, টাকা দরকার"	Money, personal info	Verify করো, তাড়াহুড়ো করো না

📞 IT Support Impersonation — Case Study

```
── ATTACK FLOW (Awareness শুধু) ──

Step 1: Research
  Attacker LinkedIn-এ দেখে:
  - IT Manager: John Rahman
  - Help Desk email: it-support@company.com
  - Employee names, positions

Step 2: Pretext Build
  Fake email: john.rahman.it@gmail.com
  (নামটা real, domain fake)

Step 3: Attack
  Email → "Hi, I'm John from IT.
  We detected unusual login from your account.
  Please confirm your password so we can investigate."

Step 4: Why it works
  ✗ Real IT manager-এর নাম ব্যবহার
  ✗ "Unusual login" = Fear trigger
  ✗ Authoritative tone
  ✗ Busy employee rushed reply

Defense:
  ✅ IT support কখনো email-এ password চায় না
  ✅ জানা নামও verify করো
  ✅ Direct phone করে confirm করো
  ✅ Ticket system ব্যবহার করো
```

🎯 CEO Fraud / BEC

BEC attack-এ attacker CEO বা CFO-র email impersonate করে Finance team-কে wire transfer করতে বলে। $26 billion-এর বেশি ক্ষতি হয়েছে বিশ্বে।

```
── BEC ATTACK EXAMPLE ──

From: ceo@company-corp.com    ← company-corp নয়, companycorp
To: finance@company.com
Subject: Urgent Wire Transfer Required

Hi Sarah,

I'm in an important meeting and need you to process
an urgent wire transfer of $85,000 to our new vendor.
This is time-sensitive and confidential.

Account: [Attacker's bank]
Please process immediately and confirm.

Regards,
David Chen, CEO

── RED FLAGS ──
❌ Urgency + Confidentiality ("don't tell anyone")
❌ Unusual domain (company-corp vs companycorp)
❌ CEO directly contacting junior employee
❌ Large amount
❌ New/unknown vendor

── DEFENSE ──
✅ Wire transfer → always phone CEO directly
✅ Dual approval process for large transfers
✅ Out-of-band verification mandatory
✅ DMARC implement করো
```

✅ Chapter 4 Summary

✓ Pretexting = believable backstory — attack-এর সবচেয়ে গুরুত্বপূর্ণ অংশ

✓ IT Support, Auditor, Vendor — সবচেয়ে বেশি ব্যবহৃত pretext

✓ BEC = CEO email spoof → finance team → wire transfer

✓ Verify করো, তাড়াহুড়ো করো না, out-of-band confirm

CHAPTER 05

🚪 Physical Social Engineering

Tailgating, Baiting, Shoulder Surfing, Dumpster Diving — Physical world-এর attack

🚶 Tailgating / Piggybacking

Tailgating মানে authorized ব্যক্তির পেছনে ঢুকে secured area-তে প্রবেশ করা। Attacker দরজা ধরে রাখার জন্য ভদ্রতাবশত কেউ না বললেই হলো।

🎭 Tailgating Techniques

- হাতে ভারী জিনিস নিয়ে "দরজা ধরুন" বলা
- Delivery person সেজে ঢোকা
- Smoke break-এ বাইরে দাঁড়িয়ে ঢোকা
- Visitor badge copy করা
- Fake contractor uniform পরা

🛡 Defense

✅ প্রতিটি ব্যক্তি নিজের card swipe করবে

✅ Mantrap / airlock door ব্যবহার করো

✅ Security guard-কে report করো

✅ Visitor badge সহজেই ভুয়া করা যায় না এমন করো

💾 Baiting

Baiting-এ attacker কিছু লোভনীয় জিনিস রেখে যায়। সবচেয়ে বিখ্যাত পদ্ধতি হলো infected USB drive parking lot-এ ফেলে রাখা।

```
── USB Drop Attack ──

Real Study (University of Michigan):
  297টি USB drive ছেড়ে রাখা হলো campus-এ
  Result: 48% USB plug করা হয়েছিল!
  "Confidential", "Salary" label দেওয়া গুলো বেশি open হলো

Attack Flow:
  1. USB-তে malware/autorun script রাখো
  2. Interesting label: "Salary 2024", "Confidential"
  3. Parking lot / lobby / toilet-এ ফেলে দাও
  4. কেউ plug করলে → reverse shell / keylogger

Defense:
  ✅ Unknown USB কখনো plug করো না
  ✅ USB autorun disable করো (Windows)
  ✅ Group Policy: USB storage block
  ✅ Awareness training

Windows — USB autorun disable:
  gpedit.msc → Computer Configuration
  → Administrative Templates → System
  → "Turn off Autoplay" = Enabled
```

👁 Shoulder Surfing ও Dumpster Diving

👁 Shoulder Surfing

কারো পেছনে দাঁড়িয়ে PIN, password বা sensitive info দেখা। ATM, cafe, public transport — সব জায়গায় হয়।

✅ Screen privacy filter ব্যবহার করো

✅ PIN টাইপ করার সময় হাত দিয়ে ঢাকো

✅ Public-এ sensitive কাজ এড়িয়ে চলো

🗑️ **Dumpster Diving**

Trash থেকে sensitive documents বের করা — bank statement, employee list, network diagrams, old passwords।

✅ Document shredder (cross-cut) ব্যবহার করো

✅ Digital-first approach — কম print করো

✅ Secure bin/locked dumpster ব্যবহার করো

✅ Chapter 5 Summary

✓ Tailgating = ভদ্রতাকে exploit — প্রত্যেকে নিজের badge swipe করবে

✓ Unknown USB কখনো plug করো না — 48% মানুষ করে

✓ Shoulder surfing — public-এ PIN ঢেকে দাও

✓ Documents shred করো — trash থেকেও attack সম্ভব

CHAPTER 06

🔍 OSINT — Target Research

Public information দিয়ে targeted attack-এর জন্য profile তৈরি

🌐 OSINT কী এবং SE-তে কেন দরকার?

OSINT (Open Source Intelligence) মানে publicly available তথ্য সংগ্রহ। Spear phishing attack শুরু করার আগে attacker target সম্পর্কে যত বেশি জানে, attack তত বেশি convincing হয়।

🕵 LinkedIn — Professional OSINT

```
LinkedIn থেকে কী পাওয়া যায়:
→ নাম, Position, Department
→ Company, Location
→ Colleague-দের নাম ও position
→ Previous employers
→ Skills, certifications
→ Recent posts (travel, projects)
→ Email pattern (firstname.lastname@company.com)

Google Dorking for LinkedIn:
site:linkedin.com "Company Name" "IT Manager"
site:linkedin.com "Company Name" "Finance"

এই তথ্য দিয়ে attacker করতে পারে:
→ "Hi John, আমি your colleague Sarah-র referred করেছেন..."
→ IT team-এর structure জেনে impersonate করা
→ Email format জেনে email guess করা
```

OSINT Tools

```
# theHarvester — email, domain, name harvest
$ theHarvester -d company.com -b all
$ theHarvester -d company.com -b linkedin,google,bing
# Output: emails, names, IPs, subdomains

# Maltego (GUI OSINT tool)
# Person → email → social accounts → phone → address
# Entity relationship mapping

# Recon-ng
$ recon-ng
[recon-ng] > modules search companies
[recon-ng] > marketplace install recon/companies-contacts/linkedin_auth
[recon-ng] > use recon/companies-contacts/linkedin_auth
[recon-ng] > set COMPANY "Target Company"
[recon-ng] > run

# Hunter.io — email finder
https://hunter.io/domain/company.com
# Email pattern + verified emails

# Shodan — device OSINT
$ shodan search org:"Company Name"
# Public-facing servers, cameras, printers

# WHOIS — domain ownership
$ whois company.com
# Registrant name, email, phone (যদি GDPR mask না করা)

# Social Searcher
https://www.social-searcher.com/
# Social media monitoring
```

নিজের Digital Footprint কমাও

📱 Social Media Privacy

- ✅ LinkedIn-এ company ও position সীমিত রাখো
- ✅ Facebook-এ workplace ও phone hide করো
- ✅ Birthday, location public করো না
- ✅ কাজের sensitive info post করো না

🌐 Online Hygiene

- ✅ WHOIS privacy/proxy ব্যবহার করো
- ✅ Data broker opt-out request পাঠাও
- ✅ Separate email for different purposes
- ✅ Google আপনার সম্পর্কে কী জানে দেখো

✅ Chapter 6 Summary

✓ LinkedIn = attacker-এর সবচেয়ে প্রিয় OSINT source

✓ theHarvester, Recon-ng, Hunter.io — email ও staff info বের করে

✓ নিজের digital footprint কমাও — public profile limit করো

CHAPTER 07

🔧 SET Toolkit — Pentest Framework

Authorized security testing-এর জন্য SET ব্যবহার — শুধুমাত্র lab/authorized environment

🚨 SET Toolkit শুধুমাত্র authorized penetration testing ও security awareness training-এর জন্য। নিজের organization বা explicit written permission ছাড়া ব্যবহার করা বেআইনি।

🛠 SET কী?

Social-Engineer Toolkit (SET) হলো TrustedSec-এর তৈরি open-source penetration testing framework। Security professionals এটা দিয়ে organization-এর employees-দের social engineering vulnerability test করে।

```
# Install (Kali Linux-এ pre-installed)
$ apt install set
$ setoolkit

── SET Main Menu ──
1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

→ 1 Select

── Social Engineering Attacks ──
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
```

```
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
```

🌐 Credential Harvester — Awareness Demo

```
── Credential Harvester (Lab Demo Only) ──

setoolkit > 1 (Social-Engineering)
         > 2 (Website Attack Vectors)
         > 3 (Credential Harvester Attack Method)
         > 2 (Site Cloner)

Enter IP address for POST back: 192.168.1.100  ← আমাদের IP
Enter URL to clone: https://example.com/login

# SET এখন example.com-এর হুবহু copy তৈরি করবে
# Victim এই fake page-এ login করলে credentials আমাদের কাছে আসবে

Output (যখন কেউ submit করবে):
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=john.doe
POSSIBLE PASSWORD FIELD FOUND: password=*****

── এই demo দিয়ে কর্মীদের দেখাও ──
→ "দেখুন, আপনার credentials কত সহজে চুরি হতে পারে"
→ এই awareness training phishing click rate 70% কমায়
```

📧 Phishing Email Simulation — SET

```
── Spear Phishing Simulation (Authorized Only) ──

setoolkit > 1 (Social-Engineering)
         > 1 (Spear-Phishing Attack Vectors)
```

```
        > 1 (Perform a Mass Email Attack)

# Email template select
# Target email enter
# Payload attach (for testing: harmless tracking pixel)

Tracking করা হয়:
→ Email কে open করেছে
→ কে link click করেছে
→ কে credentials submit করেছে
→ কে report করেছে

Report দিয়ে management-কে দেখাও:
→ "30% employee phishing click করেছে"
→ "5% credentials দিয়েছে"
→ "এই team-এর training দরকার"
```

✅ Chapter 7 Summary

✓ SET = authorized pentest tool — permission ছাড়া ব্যবহার নিষিদ্ধ

✓ Credential Harvester দিয়ে real attack কীভাবে হয় দেখাও

✓ Phishing simulation → awareness training-এর সেরা উপায়

✓ Result দিয়ে কোন team-এর training দরকার বুঝো

CHAPTER 08

Real-World Attack Cases

বিখ্যাত social engineering attack থেকে শিক্ষা নাও

Bangladesh Bank Heist (2016) — $81 Million

এটা ইতিহাসের সবচেয়ে বড় cyber bank robbery। North Korean hackers Bangladesh Bank থেকে $81 million চুরি করে। Social engineering এই attack-এর শুরু।

```
── Attack Timeline ──

2015:
  └─ Fake job application email পাঠানো হলো Bangladesh Bank-এ
  └─ Resume-তে malware ছিল
  └─ Bank employee open করলো → initial foothold

2015-2016:
  └─ SWIFT network-এ access পাওয়া গেলো
  └─ SWIFT messaging system-এর credentials চুরি
  └─ Months ধরে network monitor করা হলো

February 4-5, 2016 (Weekend):
  └─ $951 million transfer request পাঠানো হলো Federal Reserve-এ
  └─ Weekend-এ কেউ check করবে না — timing intentional
  └─ $81 million Philippines-এ গেলো (casino-তে laundered)
  └─ $870 million block হলো typo-র কারণে!
     ("fandation" লেখার ভুল = suspicious)

── Social Engineering Elements ──
→ Phishing email (initial vector)
→ Trusted channel (SWIFT) abuse
→ Timing attack (weekend)
→ Insider knowledge (bank processes)
```

```
── Lessons ──
→ Email attachment → sandbox analysis mandatory
→ Large transfers → multiple human approval
→ Weekend → automated alerts
→ SWIFT → anomaly detection
```

🦜 Twitter Hack (2020) — Obama, Biden, Musk

```
── Attack Overview ──

Target: Twitter employee credentials
Method: Vishing (phone-based social engineering)

Attack Flow:
  1. Attacker Twitter employees-দের phone করলো
  2. "আমি Twitter IT team থেকে"
  3. Internal VPN credential reset করতে সাহায্য চাইলো
  4. Employee দিয়ে দিলো → admin panel access

Result:
  → 130+ high-profile accounts hijacked
  → Obama, Biden, Musk, Apple, Uber, Gates
  → Bitcoin scam tweet করা হলো
  → $120,000+ Bitcoin collected

Attacker: 17 বছরের teenager!

── Lessons ──
→ Employee phone verification mandatory
→ Admin panel → hardware MFA (SMS MFA যথেষ্ট নয়)
→ Privileged access → strict access control
→ Social engineering awareness training
```

🧪 COVID-19 Themed Attacks (2020-2021)

```
── COVID Phishing Campaigns ──

WHO Impersonation:
  "আপনার এলাকায় COVID outbreak। Attachment-এ health form।"
  → Attachment = malware

Government Relief Scam:
  "বাংলাদেশ সরকার COVID relief দিচ্ছে।
  BDT 5,000 পেতে NID ও bKash number দিন।"
  → Identity theft

Vaccine Registration:
  "Vaccine priority registration করুন।
  Link: http://bd-vaccine-register.xyz"
  → Credential phishing

Remote Work Scam:
  "Zoom update করুন" / "VPN install করুন"
  → Actually malware

── Why it worked ──
→ Fear (সবাই scared ছিল)
→ Authority (WHO, Government impersonation)
→ Urgency (Limited time, priority registration)
→ Information hunger (নতুন কিছু জানার আগ্রহ)
```

✅ Chapter 8 Summary

✓ Bangladesh Bank — simple phishing email → $81M theft

✓ Twitter hack — phone call → admin access → 17-year-old hacker!

✓ Crisis সময়ে (COVID) fear + urgency = সবচেয়ে বেশি attack

✓ প্রতিটা case-এ human error ছিল — training দিলে আটকানো যেত

CHAPTER 09

🛡️ Defense ও Awareness Training

Organization ও ব্যক্তিকে রক্ষা করার সম্পূর্ণ framework

🏛️ Defense-in-Depth Framework

1	👥 **Human Layer**	Security awareness training, phishing simulation, clear reporting procedure
2	📋 **Policy Layer**	Data classification, clean desk policy, visitor policy, wire transfer approval process
3	🔧 **Technical Layer**	Email filtering, MFA, SPF/DKIM/DMARC, URL filtering, endpoint protection
4	🏢 **Physical Layer**	Access control, CCTV, visitor management, clean desk enforcement
5	🚨 **Incident Response**	Reporting procedure, investigation process, post-incident training

📚 Security Awareness Training Program

```
── Effective Training Program ──

1. Baseline Assessment (মাস 1)
   → Simulated phishing campaign চালাও
   → কতজন click করে? Baseline establish করো
   → Example: 35% click rate

2. Initial Training (মাস 1-2)
```

```
   → 30-min interactive module
   → Topics: Phishing, Vishing, Password, Physical SE
   → Quiz with minimum passing score (80%)
   → Real examples (Bangladesh specific)

3. Ongoing Simulations (মাসিক)
   → Monthly phishing test (different scenarios)
   → Immediately redirect those who click → micro-training
   → Track improvement over time

4. Reinforcement (quarterly)
   → New threat briefings
   → Real incident case studies
   → Department-specific training

5. Metrics (6 months later)
   → Goal: click rate < 5%
   → Track report rate (should go up)
   → Track repeat offenders

── Key Training Points ──
→ STOP - THINK - ACT (urgent request আসলে pause করো)
→ Verify করো — call করো, ticket খোলো
→ Report করো — শাস্তি নয়, culture তৈরি
→ "When in doubt, don't click"
```

🔧 Technical Controls

📧 Email Security

- ✅ SPF, DKIM, DMARC implement করো (p=reject)
- ✅ Email gateway filtering (Proofpoint, Mimecast)
- ✅ Sandbox (attachments automatically analyze)
- ✅ External email banner যোগ করো

- ✅ Link rewriting (click করলে scan হবে)

🔐 Access Control

- ✅ MFA everywhere (SMS নয়, Authenticator app)
- ✅ Privileged access management (PAM)
- ✅ Zero trust architecture
- ✅ Least privilege principle
- ✅ Password manager mandate

🖥️ Endpoint

- ✅ EDR solution (CrowdStrike, Sentinel One)
- ✅ USB disable via Group Policy
- ✅ Web filtering (malicious site block)
- ✅ Screen lock (auto after 5 min)

🏢 Physical

- ✅ Badge access (not shared)

✅ Visitor sign-in + escort

✅ Clean desk policy enforce

✅ Shredder সব desk-এ

🚨 Reporting ও Incident Response

```
── Phishing Report করার Process ──

Employee perspective:
  1. Suspicious email পেলে → Don't click
  2. Report button click করো (Outlook: "Report Phishing")
  3. অথবা IT security-কে forward করো
  4. Delete করো

Security team perspective:
  1. Report receive করো
  2. Email header analyze করো
  3. URLs VirusTotal-এ scan করো
  4. Indicators of Compromise (IOC) বের করো
  5. Organization-wide block করো
  6. অন্য কেউ click করেছে কিনা check করো
  7. Incident report তৈরি করো

Culture তৈরি করো:
→ Report করলে → ধন্যবাদ দাও, পুরস্কার দাও
→ Click করলে → blame না করে training দাও
→ Goal: সবাই reporter হবে

Blameless culture = more reports = better security
```

✅ Chapter 9 Summary

✓ Defense-in-Depth = Human + Policy + Technical + Physical + IR

✓ Phishing simulation → training → re-simulate → track improvement

✓ MFA, SPF/DKIM/DMARC, email sandbox = core technical controls

✓ Blameless reporting culture = সবচেয়ে গুরুত্বপূর্ণ

CHAPTER 10

🎣 Phishing Simulation — GoPhish

Organization-এ phishing simulation program চালানোর সম্পূর্ণ গাইড

⚠️ **GoPhish শুধুমাত্র নিজের organization-এ authorized security testing-এর জন্য। Management ও Legal-এর written approval নাও।**

⚙️ GoPhish Setup

```
# Download GoPhish
$ wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-li
$ unzip gophish-v0.12.1-linux-64bit.zip
$ cd gophish
$ chmod +x gophish
$ ./gophish

# Default credentials:
# URL: https://localhost:3333
# User: admin
# Pass: gophish (first login-এ change করো)

── Configuration ──
# config.json
{
  "admin_server": {
    "listen_url": "0.0.0.0:3333",
    "use_tls": true
  },
  "phish_server": {
    "listen_url": "0.0.0.0:80",
    "use_tls": false
```

```
  }
}
```

🎯 Campaign Setup

```
── GoPhish Campaign Steps ──

Step 1: Sending Profile তৈরি করো
  Name: "Internal IT Team"
  Interface Type: SMTP
  SMTP Host: your-smtp-server:587
  Username/Password: SMTP credentials
  → Send Test Email করে verify করো

Step 2: Landing Page তৈরি করো
  Name: "IT Portal Login"
  Import Site: https://your-company-portal.com
  → Credentials capture checkbox
  → Redirect URL (after submit): https://awareness.company.com

Step 3: Email Template তৈরি করো
  Name: "IT Security Alert"
  Envelope Sender: it-security@company.com
  Subject: "Action Required: Account Security Update"
  Body:
  "Hi {{.FirstName}},
   We detected unusual login. Please verify:
   {{.URL}}
   IT Security Team"

  → {{.FirstName}} = personalization
  → {{.URL}} = tracking URL

Step 4: Users & Groups
  CSV import:
  First Name, Last Name, Email, Position
  John, Doe, john.doe@company.com, Manager

Step 5: Campaign Launch
```

```
  Name: "Q1 2024 Phishing Simulation"
  Email Template: IT Security Alert
  Landing Page: IT Portal Login
  Launch Date: Monday 9:00 AM
  Sending Profile: Internal IT Team
  Groups: All Employees
```

📊 Metrics ও Reporting

```
── GoPhish Dashboard Metrics ──

Emails Sent:     500   (100%)
Emails Opened:   285   (57%)   ← open rate
Links Clicked:   145   (29%)   ← click rate  ← Key metric
Credentials:      42   (8.4%)  ← submit rate ← Critical
Reported:         23   (4.6%)  ← report rate ← Want this HIGH

── Industry Benchmarks ──
Initial click rate: 25-35% (no training)
After 1 year:       5-10%  (with training)
Goal:               < 5%

── Analysis করো ──
→ কোন department বেশি click করেছে?
→ কোন email template বেশি effective?
→ কোন সময়ে বেশি open হয়েছে?
→ কারা repeatedly click করছে?

── Report Structure ──
Executive Summary:
  - Overall click rate: 29% (Industry avg: 30%)
  - Credentials submitted: 42 users (critical)
  - Best performing dept: IT (5%)
  - Worst performing dept: Finance (45%)

Recommendations:
  1. Finance team-এর immediate training
  2. BEC-specific training (wire transfer policy)
```

```
3. Monthly simulation continue
4. MFA enforce করো
```

🎯 তুমি এখন কী কী পারো

🧠 Social Engineering-এর মনস্তাত্ত্বিক principles বুঝতে পারো

🎣 Phishing email-এর সব red flag চিনতে পারো

📞 Vishing ও Smishing attack চিনতে ও রক্ষা পেতে পারো

🎭 Pretexting ও impersonation কীভাবে কাজ করে জানো

🚪 Physical SE attacks (tailgating, baiting) বুঝতে পারো

🔍 OSINT দিয়ে digital footprint বিশ্লেষণ করতে পারো

🔧 SET ও GoPhish দিয়ে authorized simulation চালাতে পারো

🛡️ Organization-এর জন্য complete defense framework implement করতে পারো

🎭 "The weakest link in security is always the human."

এই গাইডের সব কিছু শুধুমাত্র শিক্ষামূলক ও defense উদ্দেশ্যে। Social engineering attack করা আইনত দণ্ডনীয়। নিজেকে ও প্রতিষ্ঠানকে রক্ষা করতে এই জ্ঞান ব্যবহার করো।

Social Engineering v1.0 — 10 Chapters | Attack & Defense | সম্পূর্ণ বাংলা গাইড